

TOSCANA DIAGNOSTICA S.r.l.

Sistema di Gestione Integrato

DOCUMENTO INFORMATIVO AMMINISTRATORE DI SISTEMA

Provvedimento Garante Privacy 27 novembre 2008
Area 08 – Sistema Informativo

Codice	Revisione	Data	Pagine
TD-SGI-REG003_00	00	12/04/2026	6
Redatto da	Approvato da	Classificazione	Stato
IT / DPO	AD – Francesco Epifani	Riservato	In vigore

Rif.: TD-SGI-PRO016 Sez. 5, 12, 13 (Gestione accessi, formazione AdS, audit log)

Responsabile del Documento	RSGI	Emissione del Documento
Francesco Epifani	Iacopo Cupelli	Francesco Epifani
12/04/2026	12/04/2026	12/04/2026

1. Premessa e base normativa

Il presente documento è redatto in conformità al Provvedimento del Garante per la protezione dei dati personali del 27 novembre 2008 (“Misure e accorgimenti prescritti ai titolari dei trattamenti effettuati con strumenti elettronici relativamente alle attribuzioni delle funzioni di amministratore di sistema”, pubblicato in G.U. n. 300 del 24 dicembre 2008), come successivamente modificato dal Provvedimento del 25 giugno 2009. Il Provvedimento impone ai titolari del trattamento di dati personali una serie di adempimenti relativi alla figura dell'amministratore di sistema, finalizzati a garantire la trasparenza, la tracciabilità e il controllo delle operazioni svolte sui sistemi informativi che trattano dati personali.

Il documento si integra nella TD-SGI-PRO016 (Procedura Sicurezza dei Sistemi Informativi), di cui costituisce un adempimento specifico, ed è coerente con il sistema di gestione della sicurezza delle informazioni ISO 27001:2022 e con il Reg. UE 2016/679 (GDPR).

2. Riferimenti normativi

Norma / Riferimento	Ambito
Provvedimento Garante 27/11/2008	Misure e accorgimenti per gli amministratori di sistema
Provvedimento Garante 25/06/2009	Modifiche al provvedimento sugli amministratori di sistema (proroga e chiarimenti)
Reg. UE 2016/679, artt. 5, 24, 28, 32	Principi di protezione dati; responsabilità del titolare; responsabile del trattamento; sicurezza del trattamento
D.Lgs. 196/2003, artt. 29, 32-34	Codice Privacy: responsabili e incaricati del trattamento; obblighi di sicurezza
D.Lgs. 101/2018	Adeguamento del Codice Privacy al GDPR
ISO 27001:2022, All. A cl. 5.2, 8.2	Politica di controllo degli accessi; gestione degli accessi privilegiati
TD-SGI-PRO016	Procedura Sicurezza dei Sistemi Informativi (Sez. 5, 12, 13)

3. Definizione di amministratore di sistema

Ai sensi del Provvedimento del Garante, per amministratore di sistema si intendono le figure professionali finalizzate alla gestione e alla manutenzione di un impianto di elaborazione o di sue componenti, compresi gli amministratori di basi di dati, gli amministratori di reti e di apparati di sicurezza, e gli amministratori di sistemi software complessi. Nell'ambito di Toscana Diagnostica, la definizione include:

- Amministratori dei sistemi operativi e delle postazioni di lavoro (configurazione, patching, hardening).
- Amministratori dei servizi cloud: Microsoft 365 (Exchange Online, SharePoint, Azure AD / Entra ID), GIPOnext, StudioLab, ZeeroMED.
- Amministratori di rete e di sicurezza: gestione firewall, switch, access point, VPN (in parte delegata al partner WIND).
- Amministratori di database: accesso alle basi dati sottostanti i sistemi LIS, RIS/PACS, CUP (generalmente in capo ai fornitori SaaS).
- Fornitori esterni che operano come amministratori di sistema nell'ambito dei contratti di assistenza e manutenzione (WIND per la rete, CB Sistemi per StudioLab, DocPlanner per GIPOnext, ZeeroMED per RIS/PACS, TWY per la fonia).

Non sono considerati amministratori di sistema gli utenti finali che utilizzano le applicazioni con profilo standard (operatori di accettazione, tecnici di laboratorio, radiologi, medici), anche se dispongono di funzionalità applicative avanzate (validazione referti, parametrizzazione strumentale).

4. Elenco degli amministratori di sistema designati

L'elenco aggiornato degli amministratori di sistema interni ed esterni è il seguente:

4.1 Amministratori interni

Nome e cognome	Funzione / Ruolo	Sistemi amministrati	Data designazione	Verifica annuale

4.2 Amministratori esterni (fornitori)

Fornitore / Società	Referente designato	Sistemi amministrati	Contratto / DPA	Verifica annuale
WIND	Da indicare	Rete, firewall, switch, AP	Contratto + DPA art. 28	
CB Sistemi	Da indicare	StudioLab (LIS)	Contratto + DPA art. 28	
DocPlanner	Da indicare	GIPOnext (CUP)	Contratto + DPA art. 28	
ZeeroMED	Da indicare	ZeeroMED (RIS/PACS)	Contratto + DPA art. 28	
TWY (ex Call2Net)	Da indicare	Centralino VoIP	Contratto + DPA art. 28	
Microsoft	N/A (piattaforma)	Microsoft 365 / Azure	DPA Microsoft OST	

L'elenco è aggiornato a ogni variazione (nuova designazione, cessazione, cambio di fornitore) e riesaminato almeno annualmente nell'ambito della verifica di cui alla Sezione 8.

5. Criteri di designazione e requisiti

La designazione degli amministratori di sistema è effettuata dal Titolare del trattamento (Toscana Diagnostica S.r.l., nella persona dell'AD) sulla base dei seguenti criteri, come richiesto dal Provvedimento del Garante:

- Esperienza, capacità e affidabilità del soggetto designato, che deve fornire idonea garanzia del pieno rispetto delle vigenti disposizioni in materia di trattamento dei dati personali, incluso il profilo relativo alla sicurezza.
- La designazione è individuale e reca l'elencazione analitica degli ambiti di operatività consentiti in base al profilo di autorizzazione assegnato.
- Per i fornitori esterni, la designazione avviene nell'ambito del contratto di servizio e del Data Processing Agreement (DPA) ai sensi dell'art. 28 del GDPR, con indicazione specifica delle persone fisiche che operano come amministratori.

6. Compiti e responsabilità dell'amministratore di sistema

L'amministratore di sistema, nell'ambito delle proprie attribuzioni, è tenuto a:

- Garantire la sicurezza dei sistemi, delle reti e delle basi dati di propria competenza, applicando le misure tecniche e organizzative definite nella TD-SGI-PRO016.
- Assicurare la disponibilità, l'integrità e la riservatezza dei dati trattati attraverso i sistemi di propria competenza.
- Gestire le credenziali di accesso privilegiate (account amministrativi) con la massima diligenza: utilizzare password complesse (almeno 16 caratteri), non condividere le credenziali, non utilizzare account generici (admin, root), cambiare la password almeno ogni 90 giorni.
- Applicare tempestivamente le patch di sicurezza e gli aggiornamenti rilasciati dai fornitori dei sistemi operativi e dei software applicativi (entro 7 giorni per le patch critiche, come previsto dalla TD-SGI-PRO016 Sez. 6).
- Configurare i sistemi in modo da garantire la registrazione degli access log (log di autenticazione) comprensivi di: identificativo dell'utente (username), data e ora dell'accesso, tipo di evento (login, logout, login fallito).
- Non accedere ai dati personali dei pazienti se non nei limiti strettamente necessari per l'espletamento delle proprie funzioni tecniche. L'accesso ai dati sanitari per finalità di manutenzione deve essere minimizzato e, ove possibile, effettuato su dati pseudonimizzati o anonimizzati.
- Segnalare immediatamente all'IT e al DPO qualsiasi anomalia, incidente di sicurezza, accesso non autorizzato o sospetta violazione dei dati personali (data breach), ai sensi della TD-SGI-PRO016 Sez. 11.
- Partecipare alla formazione annuale sulla sicurezza informatica e sulla protezione dei dati personali (4 ore, come previsto dalla TD-SGI-PRO016 Sez. 12).
- Mantenere la riservatezza su tutte le informazioni e i dati di cui viene a conoscenza nell'esercizio delle proprie funzioni, anche dopo la cessazione dell'incarico.

7. Registrazione degli accessi (access log)

In conformità al punto 4.5 del Provvedimento del Garante, Toscana Diagnostica adotta un sistema di registrazione degli accessi logici (access log) ai sistemi di elaborazione e agli archivi elettronici da parte degli amministratori di sistema. Le caratteristiche del sistema di logging sono:

- Completezza: i log registrano tutti gli eventi di autenticazione degli amministratori di sistema (login, logout, login fallito, accesso tramite VPN, accesso remoto per manutenzione) su tutti i sistemi che trattano dati personali.
- Inalterabilità: i log sono conservati in modalità non modificabile. Per i sistemi cloud (Microsoft 365, GIPOnext, StudioLab, ZeeroMED), i log sono gestiti dai rispettivi fornitori SaaS sui propri datacenter, con garanzia di inalterabilità contrattuale. Per i sistemi di rete, i log sono raccolti dal firewall e conservati dal partner WIND.
- Conservazione: i log sono conservati per un periodo non inferiore a sei mesi, come prescritto dal Provvedimento.
- Accessibilità: i log sono accessibili al DPO e al Titolare (o delegato) per le attività di verifica annuale.

Il sistema di logging registra le seguenti informazioni per ciascun evento:

Campo	Descrizione
Username / Identificativo	Nome utente o identificativo univoco dell'amministratore
Timestamp	Data e ora dell'evento (formato ISO 8601, sincronizzato NTP)
Tipo di evento	Login riuscito, login fallito, logout, sessione VPN, accesso remoto

Indirizzo IP sorgente	Indirizzo IP dal quale è stato effettuato l'accesso
Sistema / Risorsa	Sistema o risorsa a cui è stato effettuato l'accesso (nome host, servizio cloud, apparato di rete)
Esito	Successo o fallimento dell'autenticazione

8. Verifica annuale dell'operato degli amministratori

Il Titolare del trattamento, con il supporto del DPO e dell'IT, effettua almeno annualmente la verifica dell'operato degli amministratori di sistema, come prescritto dal punto 4.4 del Provvedimento. La verifica comprende:

- Analisi dei log di accesso: revisione a campione dei log degli ultimi 6 mesi per ciascun amministratore, alla ricerca di anomalie (accessi in orari insoliti, accessi da IP sconosciuti, numero elevato di login falliti, accessi a sistemi non di competenza).
- Conformità dei profili di accesso: verifica che ciascun amministratore disponga esclusivamente dei privilegi necessari per lo svolgimento delle proprie funzioni (principio del minimo privilegio).
- Aggiornamento dell'elenco: verifica che l'elenco degli amministratori (Sezione 4) sia aggiornato e che non vi siano utenze amministrative attive per soggetti cessati o non più autorizzati.
- Verifica dei fornitori esterni: per ciascun fornitore che opera come amministratore, verifica che il DPA sia in vigore, che i referenti designati siano aggiornati e che le misure di sicurezza contrattuali siano rispettate.
- Formazione: verifica che tutti gli amministratori abbiano completato la formazione annuale sulla sicurezza informatica.

L'esito della verifica è documentato in un rapporto conservato per almeno 5 anni e presentato al Riesame della Direzione (TD-SGI-PRO002). Le eventuali non conformità sono gestite con azioni correttive secondo il processo del SGI.

9. Obblighi di riservatezza e clausola di non divulgazione

Ogni amministratore di sistema, interno o esterno, è vincolato da un obbligo di riservatezza su tutte le informazioni e i dati personali di cui viene a conoscenza nell'esercizio delle proprie funzioni. Per gli amministratori interni, l'obbligo è formalizzato nella lettera di designazione e nel contratto di lavoro. Per gli amministratori esterni, l'obbligo è contenuto nel DPA e nel contratto di servizio. L'obbligo permane anche dopo la cessazione del rapporto.

10. Cessazione dell'incarico

Alla cessazione dell'incarico di amministratore di sistema (per dimissioni, cessazione del rapporto di lavoro, cessazione del contratto di servizio, revoca), si applicano le seguenti misure:

- Le credenziali di accesso privilegiato dell'amministratore cessato sono disattivate immediatamente (entro la fine dell'ultimo giorno), come previsto dalla TD-SGI-PRO016 Sez. 5.2.
- L'elenco degli amministratori (Sezione 4) è aggiornato con la data di cessazione.
- I log relativi all'amministratore cessato sono conservati per almeno sei mesi dalla data di cessazione.
- Eventuali dispositivi aziendali in dotazione all'amministratore cessato sono restituiti e sottoposti a verifica (cancellazione sicura di eventuali dati residui).

11. Modulo di presa visione dell'amministratore

DICHIARAZIONE DI PRESA VISIONE E ACCETTAZIONE	
Io sottoscritto/a (nome e cognome)	
Funzione / Società	
Sistemi amministrati	

Dichiaro di aver preso visione del presente Documento Informativo per gli Amministratori di Sistema (TD-SGI-REG003) e di accettare integralmente gli obblighi e le responsabilità in esso contenuti, con particolare riferimento a:

- I compiti e le responsabilità di cui alla Sezione 6.
- Il sistema di registrazione degli accessi di cui alla Sezione 7.
- La verifica annuale dell'operato di cui alla Sezione 8.
- Gli obblighi di riservatezza di cui alla Sezione 9.

Mi impegno a svolgere le funzioni di amministratore di sistema con la massima diligenza, nel rispetto della normativa in materia di protezione dei dati personali e delle procedure del SGI di Toscana Diagnostica.

Firma dell'amministratore	Firma del Titolare (o delegato)
Luogo e data	Luogo e data

12. Storico delle revisioni

Rev.	Data	Descrizione modifiche	Approvazione
00	12/04/2026	Prima emissione	Francesco Epifani